

AI Trust & Safety Auditing Agent

JSON Schema Documentation v3.1

Project: AI-Based Accounting Information Systems Auditing Framework

Author: Wenguang Li, MASY Student

Date: March 7, 2026

Version: 3.1 (Enhanced with GDPR/CCPA Privacy Compliance)

Table of Contents

- 1. Introduction
 - 2. Version History
 - 3. Schema Overview
 - 4. Module 1: Governance & Compliance
 - 5. Module 2: Fairness & Bias
 - 6. Module 3: Security & Privacy
 - 7. Module 4: Explainability & Audit Trail
 - 8. Module 5: Accuracy & Performance
 - 9. Regulatory Alignment Matrix
 - 10. Interdependency Triggers
 - 11. Council of Experts Integration
 - 12. Evidence Requirements
 - 13. Scoring Methodology
 - 14. SOX 404 Classification
 - 15. Implementation Guide
 - 16. Validation & Testing
-

1. Introduction

Purpose

This documentation describes the JSON schema specifications for the AI Trust & Safety Auditing Agent, a multi-module ensemble system designed to evaluate AI-based Accounting Information Systems (AIS) for compliance with:

- **SOX 404** (Internal Control over Financial Reporting)
- **PCAOB Standards** (AS 1105, AS 2110, AS 2201, AS 2501)
- **GAAP/IFRS** (ASC 606, 815, 350-40)
- **NIST AI RMF 1.0** (GOVERN, MAP, MEASURE, MANAGE)

- **ISO 42001:2023** (AI Management System)
- **EU AI Act** (Regulation 2024/1689 - High-risk AI requirements)
- **GDPR** (General Data Protection Regulation - Privacy compliance)
- **CCPA/CPRA** (California Consumer Privacy Act - Data rights)

Scope

The schemas define evaluation criteria, evidence requirements, scoring methodologies, and regulatory mappings for five specialized audit modules:

1. **Module 1:** Governance & Compliance
2. **Module 2:** Fairness & Bias
3. **Module 3:** Security & Privacy
4. **Module 4:** Explainability & Audit Trail
5. **Module 5:** Accuracy & Performance

Key Features

- **Machine-readable specifications** enabling automated compliance gap analysis
- **Evidence templates** with PCAOB AS 1105 sufficiency standards
- **Materiality calculations** translating technical findings to financial impact
- **Interdependency triggers** coordinating multi-module responses
- **GDPR/CCPA integration** for privacy compliance (new in v3.1)
- **Council of Experts** peer review architecture (new in v3.1)

2. Version History

Version	Date	Major Changes
1.0	2026-01-15	Initial framework with 5 modules, 17 criteria
2.0	2026-02-10	Added interdependency triggers, materiality framework
3.0	2026-02-28	Added Council of Experts three-stage peer review
3.1	2026-03-07	GDPR/CCPA privacy regulations integrated across all modules; Module 3 expanded to Security & Privacy; 28 total criteria (was 17); New evidence templates (ROPA, DPIA, breach notification, data retention)

v3.1 Highlights

Privacy Compliance Integration: - GDPR (16 articles) and CCPA/CPRA (10 sections) mapped across all modules - Module 3 expanded: 3 → 6 criteria (Privacy by Design, Breach Notification, Data Retention) - New privacy governance criteria in Module 1 (ROPA, DPIA oversight) - Automated decision-making opt-out rights (Modules 2, 4) - Personal data accuracy requirements (Module 5)

Criteria Growth: 17 → 28 (+65%)

3. Schema Overview

Detailed Schemas in Github (<https://github.com/ZLYONZ/AI-Trust-Safety-Auditing-Agent/tree/main/interface-contracts>)

Architecture

Each module schema follows a consistent structure:

```
{
  "$schema": "http://json-schema.org/draft-07/schema#",
  "title": "Module X: [Module Name] Evaluation Schema",
  "version": "3.1",
  "module_id": "MX_MODULE_NAME",
  "evaluation_criteria": [ /* Criteria array */ ],
  "aggregate_scoring": { /* Scoring methodology */ },
  "regulatory_alignment": { /* Compliance mappings */ },
  "interdependency_triggers": [ /* Cross-module triggers */ ],
  "council_of_experts_integration": { /* Peer review */ }
}
```

Key Sections

Evaluation Criteria: - Criterion ID (e.g., G1.1, F2.1) - Description and check methods - Pass criteria definitions - Evidence requirements with field specifications - Scoring methodology (thresholds, weights) - Severity mapping (Material Weakness, Significant Deficiency, Pass)

Aggregate Scoring: - Weighted average methodology - Overall pass thresholds - Geographic exemption handling (GDPR/CCPA N/A cases)

Regulatory Alignment: - SOX 404 component mapping - NIST AI RMF subcategory mapping - ISO 42001 clause mapping - EU AI Act article mapping - GDPR article mapping (new in v3.1) - CCPA section mapping (new in v3.1)

Interdependency Triggers: - Trigger conditions (score thresholds) - Target modules activated - Actions and rationale

Council of Experts Integration: - Stage 1: Domain score calculation - Stage 2: Peer review lens (questions each module asks) - Stage 3: Arbitrator inputs

4. Module 1: Governance & Compliance

Overview

Module ID: M1_GOVERNANCE

Criteria Count: 7 (was 5 in v2.0)

Pass Threshold: 0.75

Primary Standards: SOX 404, ISO 42001, GDPR Articles 24/30/35

Criteria Summary

ID	Criterion	Weight	Key Requirement
G1.1	AI Governance Policy	20%	Board-approved policy with 7 sections including privacy governance
G1.2	Risk Management System	18%	≥5 documented AI risks, quarterly monitoring
G1.3	SOX 404 Control Documentation	18%	≥10 controls, COSO mapping, quarterly testing
G1.4	AI System Inventory	12%	All systems documented, quarterly updates
G1.5	Training & Competency	12%	≥80% personnel trained, ≥85% assessment pass rate
G1.6	ROPA Maintenance (GDPR)	10%	Record of Processing Activities per Article 30
G1.7	DPIA Governance (GDPR)	10%	DPO consultation, governance oversight of high-risk AI

NEW in v3.1: Privacy Governance Criteria

G1.6: ROPA Maintenance (GDPR Article 30)

Purpose: Validates Record of Processing Activities for AI systems processing personal data

Required Fields: - Processing activities (name, purposes, data subjects, data categories) - Recipients and third-country transfers - Retention periods - Security measures - Legal basis per activity

Pass Criteria: - All AI processing activities documented - Updated within 12 months - DPO reviewed (if applicable) - All Article 30 required fields present

Geographic Applicability: - Required if processing EU resident data - Scored N/A with exemption documentation if not applicable

Scoring: - 1.0: All activities, all fields, ≤6 months old - 0.75: All activities, minor gaps, ≤12 months - 0.5: Most activities, significant gaps - 0.0: Incomplete or missing

G1.7: High-Risk AI DPIA Governance

Purpose: Ensures governance oversight of Data Protection Impact Assessments

Required Components: - DPIA governance procedure - DPO consultation logs - Governance committee review documentation - Remediation tracking

Pass Criteria: - DPO consulted for all high-risk AI DPIAs - Governance committee reviews DPIAs - Findings tracked and remediated

Scoring: - Procedure quality: 35% - DPO consultation: 30% - Governance oversight: 25% - Remediation tracking: 10%

Interdependency Triggers

T1.1: G1.1 < 0.5 → Triggers Module 2 (escalate fairness testing 10% → 50%)

T1.2: G1.6 or G1.7 < 0.6 → Triggers Module 3 (escalate privacy criteria testing)

Evidence Templates

G1.1-E1: AI Governance Policy Document - Format: PDF/DOCX with version control - Minimum sections: 7 (scope, roles, RACI, risk, ethics, compliance, privacy) - Approval: Board signature within 12 months

G1.6-E1: ROPA (Record of Processing Activities) - Format: Excel with Article 30 template - Required columns: Activity, purposes, data subjects, data categories, recipients, transfers, retention, security - Update: Within 12 months

G1.7-E1: DPIA Governance Procedure - Format: PDF procedure document - Contents: Triggers, methodology, DPO consultation requirement, approval authority - Approval: Legal/DPO within 12 months

5. Module 2: Fairness & Bias

Overview

Module ID: M2_FAIRNESS

Criteria Count: 4 (was 3 in v2.0)

Pass Threshold: 0.75

Primary Standards: NIST AI RMF Fairness, GDPR Article 9/22, CCPA §1798.125

Criteria Summary

ID	Criterion	Weight	Key Requirement
F2.1	Fairness Metrics & Special Category Data	35%	Demographic parity $\pm 5\%$, disparate impact 0.8-1.25, legal basis for special category data
F2.2	Bias Monitoring System	25%	Monthly monitoring minimum, <72hr alert response
F2.3	Bias Mitigation Procedures	25%	≥ 2 techniques implemented, effectiveness validated
F2.4	Automated Decision Opt-Out (GDPR/CCPA)	15%	Opt-out mechanism, human review available ≤ 5 days

NEW in v3.1: Privacy Compliance

F2.1 Enhanced: Special Category Data Compliance

GDPR Article 9 Requirements: - Special category data = race, ethnic origin, health, political opinions, etc. - Requires **explicit consent** or other legal basis - Higher protection standards

Evidence Requirements: - Legal basis documentation (which Article 9 exemption applies) - Consent records (if using consent) - Opt-in mechanisms - Consent withdrawal procedures - Consent logs

Scoring Component (25% of F2.1): - 1.0: Legal basis documented, explicit consent where required, DPO/legal approval - 0.75: Legal basis documented, minor consent gaps - 0.5: Partial documentation - 0.0: No legal basis for special category data processing

F2.4: Automated Decision-Making Opt-Out (NEW)

GDPR Article 22 Rights: - Right NOT to be subject to solely automated decision-making - Right to obtain human intervention - Right to express point of view - Right to contest decision

CCPA §1798.185 Rights: - Right to opt-out of automated decision-making - Right to know about AI use in decisions - Non-discrimination for exercising rights

Required Evidence: - Opt-out procedure documentation - Human review request logs - Privacy policy AI disclosure - Alternative non-AI decision process

Pass Criteria: - Opt-out mechanism operational and tested - Human review available within 5 business days - Privacy policy discloses automated decision use - Alternative process available

Scoring: - Opt-out mechanism: 30% - Human review availability: 30% - Privacy policy disclosure: 20% - Alternative process: 20%

Applicability: - Required if AI makes decisions with legal/significant effects - Required if processing EU/California resident data - Otherwise scored N/A with exemption documentation

Fairness Metrics Specifications

Demographic Parity:

Acceptable: $|\text{approval_rate_group_A} - \text{approval_rate_group_B}| \leq 5\%$
Ideal: $\leq 3\%$

Disparate Impact:

Acceptable: $0.80 \leq (\text{selection_rate_group_A} / \text{selection_rate_group_B}) \leq 1.25$
Ideal: 0.90-1.10

Equalized Odds:

Acceptable: $|\text{TPR_A} - \text{TPR_B}| < 10\%$ AND $|\text{FPR_A} - \text{FPR_B}| < 10\%$
Ideal: Both $< 5\%$

Interdependency Triggers

T2.1: $\text{F2.1} < 0.6 \rightarrow$ Triggers Module 5 (analyze accuracy across demographics)

T2.2: $\text{F2.4} < 0.6 \rightarrow$ Triggers Module 1 (investigate privacy governance gap)

6. Module 3: Security & Privacy

Overview

Module ID: M3_SECURITY_PRIVACY

Criteria Count: 6 (MAJOR EXPANSION from 3 in v2.0)

Pass Threshold: 0.75

Primary Standards: ISO 27001, NIST Secure & Resilient, GDPR Articles 5/25/32-35, CCPA §1798.100-199

Criteria Summary

ID	Criterion	Weight	Key Requirement
S3.1	Data Protection & Encryption	15%	AES-256 at rest, TLS 1.3 in transit
S3.2	Adversarial Robustness	15%	Penetration testing within 12 months
S3.3	Access Control & Authorization	15%	RBAC, least privilege, quarterly reviews
S3.4	Privacy by Design & Default (GDPR)	20%	DPIA complete, ROPA maintained, default privacy settings
S3.5	Breach Detection & Notification (GDPR/CCPA)	20%	72-hour notification capability, breach detection operational
S3.6	Data Minimization & Retention (GDPR/CCPA)	15%	Retention policies, automated deletion, erasure/delete rights

NEW in v3.1: Comprehensive Privacy Criteria

S3.4: Privacy by Design & Default (GDPR Article 25)

Components:

- DPIA (Data Protection Impact Assessment)** - GDPR Article 35
 - Required for high-risk AI processing
 - 5 required sections:
 - Systematic description of processing
 - Necessity and proportionality assessment
 - Risks to rights and freedoms
 - Mitigation measures
 - DPO consultation record
 - Must be signed by DPO or legal counsel
 - Updated within 12 months
- ROPA (Record of Processing Activities)** - GDPR Article 30
 - Excel/CSV format
 - Required fields: Processing activities, purposes, data categories, recipients, retention, security
 - Updated within 12 months
- Privacy by Default**
 - Default settings maximize privacy

- Opt-in for data collection (not opt-out)
- Data minimization evidence

Scoring: - DPIA quality: 35% - ROPA completeness: 30% - Privacy by default: 20% - Data minimization: 15%

Pass Criteria: - DPIA complete with all 5 sections, DPO consulted - ROPA covers all AI processing, updated ≤12 months - Default settings privacy-protective - Data minimization documented

S3.5: Breach Detection & Notification

GDPR Requirements (Articles 33-34): - 72-hour notification to supervisory authority - Notification to affected individuals “without undue delay” - Breach log maintained

CCPA Requirements (§1798.82, §1798.150): - Prompt notification to California AG - Notification to >500 affected residents - Private right of action for breaches

Required Evidence: - Breach detection mechanisms (automated preferred) - Incident response RACI - GDPR 72-hour notification procedure - CCPA California AG notification procedure - Breach notification templates - Incident response testing logs

Scoring: - Breach detection: 30% - GDPR 72-hour capability: 35% - CCPA notification: 20% - Incident response RACI: 15%

Materiality Impact Formula:

$$\begin{aligned} \text{Breach_Impact} = & (\text{Per_Record_Cost} \times \text{Records_Affected}) \\ & + (\text{GDPR_Fine_Exposure}) \\ & + (\text{CCPA_Fine_Exposure}) \\ & + (\text{Notification_Cost}) \end{aligned}$$

Where:

- Per_Record_Cost: \$150-\$250 (financial data)
- GDPR_Fine_Max: €20M or 4% global turnover (Article 83(5))
- CCPA_Fine_Max: \$7,500/intentional violation, \$2,500/unintentional
- CCPA_Private_Action: \$100-\$750 per consumer per incident
- Notification_Cost: \$50k-\$500k (GDPR 72hr + CCPA processes)

Example:

$$\begin{aligned} & 100,000 \text{ records breach:} \\ & = (100,000 \times \$200) + €20\text{M} + \$10\text{M (CCPA)} + \$200\text{k} \\ & = \$20\text{M} + \$22\text{M} + \$10\text{M} + \$0.2\text{M} \\ & = \$52.2\text{M potential impact} \end{aligned}$$

If Overall Materiality = \$5M → 10.4× → MATERIAL WEAKNESS

S3.6: Data Minimization & Retention

GDPR Requirements: - Article 5(1)(c): Data minimization (collect only necessary data) - Article 5(1)(e): Storage limitation (retain only as long as necessary) - Article 17: Right to erasure (“Right to be Forgotten”)

CCPA Requirements: - §1798.105: Right to delete personal information - §1798.106: Right to correct inaccurate information

Required Evidence: - Data retention policy with justified retention periods - Automated deletion procedures - Deletion logs - GDPR Right to Erasure request process (30-day response) - CCPA Right to Delete request process (45-day response) - Deletion verification methods

Scoring: - Retention policy: 25% - Automated deletion: 30% - GDPR erasure rights: 25% - CCPA delete rights: 20%

Interdependency Triggers

T3.1: S3.1/S3.2/S3.3 < 0.7 → Triggers Module 1 (investigate governance root cause)

T3.2: S3.5 < 0.6 OR actual breach → Triggers Module 1 (calculate GDPR/CCPA fine exposure, assess materiality)

7. Module 4: Explainability & Audit Trail

Overview

Module ID: M4_EXPLAINABILITY

Criteria Count: 5 (was 3 in v2.0)

Pass Threshold: 0.80 (higher due to critical nature for audit validity)

Primary Standards: PCAOB AS 1105, NIST Explainable & Interpretable, GDPR Articles 13-14/22, CCPA §1798.100/185

Criteria Summary

ID	Criterion	Weight	Key Requirement
E4.1	AI Decision Explainability & GDPR Transparency	30%	SHAP/LIME for ≥95% decisions, meaningful plain language explanations
E4.2	Audit Trail Completeness	30%	100% decisions logged, 7-year retention, immutable
E4.3	Model Documentation & Version Control	20%	Model cards with 9 sections, version control operational
E4.4	Human Review Mechanism (GDPR Article 22)	10%	Human intervention available, ≤5 days response, contestation process
E4.5	CCPA Opt-Out & Right to Know	10%	Privacy policy disclosure, opt-out operational, logic access

NEW in v3.1: Transparency & Rights

E4.1 Enhanced: GDPR Meaningful Information

Technical Explainability: - SHAP values or LIME explanations - Feature importance - Decision traceability to source data - Coverage: $\geq 95\%$ of decisions

GDPR Transparency (Articles 13-14): - Meaningful information about automated decision-making - Plain language (not just technical) - Must disclose: - Logic of processing - Significance of processing - Envisaged consequences for data subject

Evidence Requirements: - SHAP/LIME technical outputs - Plain language explanation examples - Readability scores - Legal review confirmation of GDPR compliance

Scoring: - Technical explainability: 40% - Decision traceability: 30% - GDPR meaningful information: 20% - Explanation quality: 10%

GDPR component scored N/A if not processing EU resident data

E4.4: Human Review Mechanism (NEW)

GDPR Article 22(3) Rights: - Right to obtain human intervention - Right to express point of view - Right to contest decision

Required Evidence: - Human review procedure - Reviewer training records - Review request logs (with turnaround times) - Contestation procedure - Escalation path

Pass Criteria: - Human review available upon request - Reviewers trained and qualified - $\geq 95\%$ reviews completed within 5 business days - Data subjects can express view and contest

Scoring: - Procedure existence: 25% - Reviewer competence: 25% - Response timeliness: 25% - Contestation mechanism: 25%

Applicability: Required for solely automated decisions with legal/significant effects on EU residents

E4.5: CCPA Opt-Out & Right to Know (NEW)

CCPA §1798.100 - Right to Know: - Categories of personal information used in AI - Purposes of automated decision-making - Right to access decision logic

CCPA §1798.185 - Opt-Out: - Right to opt-out of automated decision-making - Alternative service must be available

CPRA §1798.185(a)(16) - Logic Access: - Right to access logic behind automated decisions - Right to request correction

Required Evidence: - Privacy policy excerpt (AI use disclosure) - Opt-out mechanism - Consumer request handling logs - Logic disclosure documentation

Scoring: - Privacy policy disclosure: 30% - Opt-out mechanism: 30% - Request handling (45-day timeline): 25% - Logic access: 15%

Critical Interdependency Trigger

T4.1: E4.1 or E4.2 < 0.7 → Triggers ALL MODULES

Action: Flag all findings as “Lower Confidence”, escalate to HITL, potential PCAOB AS 1105 scope limitation

Rationale: Without adequate explainability and audit trail, auditors cannot validate findings from other modules. This creates a potential scope limitation in the external audit.

8. Module 5: Accuracy & Performance

Overview

Module ID: M5_ACCURACY

Criteria Count: 5 (was 3 in v2.0)

Pass Threshold: 0.75

Primary Standards: NIST Valid & Reliable, COSO Monitoring, GAAP ASC 606/815, GDPR Article 5(1)(d), CCPA §1798.106

Criteria Summary

ID	Criterion	Weight	Key Requirement
A5.1	Model Validation & Data Accuracy	30%	Confusion matrix, ROC/PR, ≥20% holdout, personal data accuracy validated
A5.2	Drift Monitoring with GDPR Compliance	30%	Daily monitoring, 5%/10%/15% alert thresholds, GDPR accuracy triggers
A5.3	Performance Dashboard & Materiality	15%	Daily refresh, materiality calculation displayed
A5.4	Personal Data Inference Accuracy (GDPR)	15%	AI inferences validated for accuracy, correction analysis
A5.5	Data Subject Correction Rights (GDPR/CCPA)	10%	Correction procedures, 30-day (GDPR) / 45-day (CCPA) timelines

NEW in v3.1: Personal Data Accuracy Compliance

A5.1 Enhanced: GDPR Article 5(1)(d) Data Accuracy

Accuracy Principle: > “Personal data shall be... accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate... are erased or rectified without delay.”

Additional Validation Required: - Validation specifically assessing accuracy of **AI inferences about individuals** - Not just overall model accuracy, but accuracy of personal data generated by AI - Analysis of data subject correction requests revealing systematic issues

Evidence Requirements: - Personal data validation report - Accuracy principle compliance assessment - Correction request analysis for systematic errors

Scoring Component (15% of A5.1): - Personal data inference accuracy specifically validated - Correction request analysis performed - Systematic accuracy issues addressed

A5.2 Enhanced: GDPR Accuracy Degradation Triggers

Additional Monitoring: When drift >10% detected, must assess: - Does drift cause personal data inferences to become inaccurate? - Trigger for GDPR Article 16 (right to rectification) - Automated correction procedures where possible

Evidence: - Drift impact on personal data assessment - Correction obligation trigger documentation - Automated correction procedures

A5.4: Personal Data Inference Accuracy (NEW)

Purpose: Ensure AI-generated personal data (inferences) is accurate per GDPR Article 5(1)(d)

Inference Types: - Credit scores - Risk ratings - Approval probabilities - Customer classifications - Fraud scores

Validation Methodology: - How inferences are validated for accuracy - Representative sample tested - Accuracy metrics (precision, recall, FPR) - Ground truth comparison

Correction Request Analysis: - GDPR Article 16 / CCPA §1798.106 requests received - Systematic error pattern detection - Impact on model (triggers retraining if patterns found)

Pass Criteria: - Comprehensive inference validation (>95% accuracy) - Correction requests systematically analyzed - No systematic errors OR errors addressed through retraining - Rectification procedures operational

Scoring: - Inference validation: 40% - Correction analysis: 30% - Rectification procedures: 20% - Proactive monitoring: 10%

A5.5: Data Subject Correction Rights (NEW)

GDPR Article 16 - Right to Rectification: - Data subjects can request correction of inaccurate personal data - Controller must respond within **30 days** - Must rectify OR explain why data is accurate

CCPA §1798.106 - Right to Correct: - Consumers can request correction of inaccurate personal information - Business must respond within **45 days** - Must correct upon verified request

Required Evidence: - Correction request procedure - Request handling logs (with turnaround times) - Model impact assessment process - Systematic error detection methodology - Retraining trigger thresholds

Pass Criteria: - Procedure documented and approved - ≥95% requests within statutory timeline - Systematic error detection operational - Retraining performed when warranted - Data subjects notified of outcomes

Scoring: - Procedure quality: 30% - Timeline compliance: 35% - Systematic error detection: 25% - Notification compliance: 10%

Materiality Calculation

Formula:

$$\text{Potential_Misstatement} = \text{Error_Rate} \times \text{Transaction_Value} \times \text{Bias_Factor}$$

Where:

- Error_Rate: Model error rate from validation (e.g., 2.98%)
- Transaction_Value: Annual transactions processed by AI (e.g., \$500M)
- Bias_Factor: Error concentration multiplier
 - 1.0 = Uniformly distributed errors
 - 3.0 = Errors concentrated in high-value transactions
 - 5.0 = Extreme concentration (e.g., all errors in top 10% of transactions)

Example:

Revenue Recognition AI:

- Error Rate: 2.98%
- Transaction Value: \$500M
- Bias Factor: 3.0 (errors concentrated in large contracts)

$$\text{Potential_Misstatement} = 0.0298 \times \$500\text{M} \times 3.0 = \$44.7\text{M}$$

If Overall Materiality = \$5M:

$$\text{Materiality Multiple} = \$44.7\text{M} \div \$5\text{M} = 8.94\times$$

SOX Classification: MATERIAL WEAKNESS (exceeds materiality by 8.94×)

Classification Rules: - **Material Weakness:** Materiality_Multiple > 1.0 - **Significant Deficiency:** 0.5 < Materiality_Multiple ≤ 1.0 - **Control Deficiency:** Materiality_Multiple ≤ 0.5

Interdependency Triggers

T5.1: A5.2 drift > 10% → Triggers Module 4 (SHAP correlation analysis: concept drift vs. model breakdown)

T5.2: Materiality impact > threshold → Triggers Module 1 (investigate deployment approval governance)

T5.3: A5.4 or A5.5 < 0.6 → Triggers Module 1 (investigate privacy governance for accuracy obligations)

9. Regulatory Alignment Matrix

Complete Regulatory Coverage

Regulation	Articles/Sections	Applicable Modules	Purpose
SOX 404	ICFR	All	Internal control evaluation
PCAOB AS 1105	Audit Evidence	M4, All	Evidence sufficiency
GAAP ASC 606	Revenue Recognition	M5	Accuracy for revenue AI

Regulation	Articles/Sections	Applicable Modules	Purpose
NIST AI RMF	All 7 characteristics	All	AI trustworthiness
ISO 42001	Clauses 4-10	All	AI management system
EU AI Act	Articles 9-15	All	High-risk AI requirements
GDPR	16 articles	All	Privacy compliance
CCPA/CPRA	10 sections	All	California data rights

GDPR Article Mapping

GDPR

Article	Module	Criteria	Requirement
Article 5	M3, M5	S3.6, A5.1, A5.2	Principles (accuracy, minimization, storage limitation)
Article 9	M2	F2.1	Special category data (explicit consent required)
Articles 13-14	M4	E4.1, E4.4	Right to meaningful information about automated decisions
Article 16	M5	A5.4, A5.5	Right to rectification of inaccurate personal data
Article 17	M3	S3.6	Right to erasure (“Right to be Forgotten”)
Article 22	M2, M4	F2.4, E4.4	Right not to be subject to solely automated decisions
Article 24	M1	G1.1	Controller responsibility
Article 25	M3	S3.4	Privacy by Design and Default
Article 30	M1, M3	G1.6, S3.4	Records of Processing Activities (ROPA)
Articles 32-34	M3	S3.5	Security + breach notification (72 hours)
Article 35	M1, M3	G1.7, S3.4	Data Protection Impact Assessment (DPIA)

CCPA/CPRA Section Mapping

CCPA Section	Module	Criteria	Requirement
§1798.100	M1, M4	G1.6, E4.5	Right to know what data collected
§1798.105	M3	S3.6	Right to delete personal information
§1798.106	M5	A5.4, A5.5	Right to correct inaccurate information
§1798.125	M2, M4	F2.4, E4.5	Non-discrimination for exercising rights
§1798.130	M1, M3	G1.1, S3.4	Business security and privacy policy obligations
§1798.150	M3	S3.5	Private right of action for data breaches
§1798.185	M2, M4, M5	F2.4, E4.5, A5.2	Automated decision-making regulations, opt-out
§1798.185(a)(16)	M4	E4.5	Right to access logic and request correction

CCPA Section	Module	Criteria	Requirement (CPRA)
--------------	--------	----------	-----------------------

10. Interdependency Triggers

Overview

Interdependency triggers enable coordinated multi-module responses when findings in one module indicate higher risk in another. This creates an intelligent “defense-in-depth” system.

All Triggers

Trigger ID	Source	Target	Condition	Action
T1.1	M1	M2	$G1.1 < 0.5$	Escalate fairness testing 10% → 50%
T1.2	M1	M3	$G1.6 \text{ or } G1.7 < 0.6$	Escalate privacy criteria testing
T2.1	M2	M5	$F2.1 < 0.6$	Analyze accuracy across demographics
T2.2	M2	M1	$F2.4 < 0.6$	Investigate privacy governance gap
T3.1	M3	M1	$S3.1/2/3 < 0.7$	Investigate governance root cause
T3.2	M3	M1	$S3.5 < 0.6$ OR breach	Calculate GDPR/CCPA fine exposure
T4.1	M4	ALL	$E4.1 \text{ or } E4.2 < 0.7$	Flag all findings “Lower Confidence”, HITL escalation
T5.1	M5	M4	$\text{Drift} > 10\%$	SHAP analysis: concept drift vs. breakdown
T5.2	M5	M1	Materiality exceeded	Investigate deployment approval
T5.3	M5	M1	$A5.4 \text{ or } A5.5 < 0.6$	Investigate privacy governance

Critical Trigger: T4.1 (Explainability Failure)

Trigger: $E4.1 \text{ or } E4.2 < 0.7$

Impact: ALL MODULES affected

Action: 1. Flag all findings from M1, M2, M3, M5 as “Lower Confidence” 2. Escalate to human auditors (HITL) 3. Assess potential PCAOB AS 1105 scope limitation 4. May result in disclaimer of opinion if explainability cannot be remediated

Rationale: Without adequate explainability and audit trail: - Cannot verify governance controls (M1) - Cannot validate fairness metrics (M2) - Cannot test security measures (M3) - Cannot substantiate accuracy claims (M5)

This creates insufficient audit evidence per PCAOB AS 1105.

11. Council of Experts Integration

Three-Stage Peer Review System (v3.0+)

Stage 1: Independent Scoring

Each module produces a domain score (0-100) using:

Score Decomposition: - Evidence Quality: 25% - Criteria Coverage: 30% - Regulatory Alignment: 25% - Materiality Weighting: 20%

Scoring Rubric: - 90-100: Exemplary - 70-89: Satisfactory - 50-69: Needs Improvement - 30-49: Deficient - 0-29: Critical/Material Weakness

Stage 2: Cross-Module Peer Review

Each module reviews the other 4 modules anonymously.

Peer Review Card Outputs: - Cross-Domain Score (1-10 rating) - Blind-Spot Flags (gaps the original module missed) - Consistency Check (logical coherence) - Escalation Recommendation (Agree / Escalate Higher / Lower / Flag for Arbitration)

Cross-Domain Review Lenses:

Example: **Module 1 reviews Module 2** - Does governance framework mandate bias detection? - Are fairness accountability owners assigned? - Do governance policies address demographic equity?

Example: **Module 5 reviews Module 2** - Does accuracy vary systematically across demographics? - Is model more error-prone for protected classes? - Are fairness metrics statistically reliable?

Stage 3: Arbitrator Synthesis

Arbitrator Inputs: - 5 domain scores (Stage 1) - 20 peer review cards (5 modules × 4 peers, Stage 2) - Orchestrator interdependency trigger log

Arbitrator Outputs: - Final Composite Score (confidence-weighted) - Consensus Map (≥4 modules agree) - Divergence Map (score spread ≥20 points) - Materiality Confidence Adjustment - Council Scorecard (appended to audit report)

Divergence Handling

Divergence Level	Score Spread	Action
Low	<10 pts	Standard weighted average
Moderate	10-19 pts	Document disagreement, include note
High	20-34 pts	Auto HITL escalation, written reconciliation
Critical	≥35 pts	Suspend automated scoring, mandatory human review

12. Evidence Requirements

Evidence Template Structure

All evidence follows consistent structure:

```
{  
  "evidence_id": "[Criterion_ID]-E[#]",  
  "evidence_type": "[Type]",  
  "required_fields": { /* Field specifications */ },  
  "file_formats": ["PDF", "Excel", "CSV", etc.],  
  "approval_requirements": "[Who must approve and when]",  
  "retention_period": "7 years (SOX 404)",  
  "pcaob_standards": "AS 1105 sufficiency and appropriateness"  
}
```

Privacy-Specific Evidence Templates (NEW in v3.1)

ROPA (Record of Processing Activities)

File: G1.6-E1 / S3.4-E1

Format: Excel with Article 30 template

Columns: - Processing activity name - Purposes of processing - Categories of data subjects - Categories of personal data - Recipients (internal and external) - Third-country transfers - Retention periods - Security measures description

Update Frequency: Within 12 months

Approval: DPO or legal counsel

DPIA (Data Protection Impact Assessment)

File: S3.4-E2

Format: PDF structured report

Required Sections: 1. Systematic description of processing operations and purposes 2. Assessment of necessity and proportionality 3. Assessment of risks to rights and freedoms of data subjects 4. Measures to address risks 5. DPO consultation record (if DPO appointed)

Trigger: Required for high-risk AI processing (automated decision-making with legal/significant effects)

Update: When processing changes materially or every 3 years

Approval: DPO signature

Breach Notification Procedures

File: S3.5-E1

Format: Policy document + incident response logs

Components: - GDPR 72-hour notification procedure - Supervisory authority contact information - Notification template (what to include per Article 33) - Breach assessment criteria (when notification required) - CCPA California AG notification procedure - AG contact information - >500 resident trigger documentation - Consumer notification template - Incident response team RACI - Breach detection mechanisms - Testing logs (tabletop exercises)

Testing Frequency: Annually
Approval: Legal/DPO and IT Security

Data Retention & Deletion Policy

File: S3.6-E1

Format: Policy document with retention schedules

Components: - Retention periods per data category with legal basis - Automated deletion procedures - Manual deletion procedures (when automation not possible) - Deletion verification methods - Legal hold process - GDPR Article 17 (Right to Erasure) response procedure - CCPA §1798.105 (Right to Delete) response procedure

Update: Annually

Approval: Legal/DPO

Statistical Rigor Requirements

All quantitative evidence must include: - **95% confidence intervals** for key metrics - **Statistical significance testing** ($p < 0.05$) - **Sample size justification** (power analysis where applicable) - **Independent validation** (validator not model developer)

13. Scoring Methodology

Criterion-Level Scoring

Each criterion uses one of these methods:

1. Binary with Partial Credit

```
{  
  "method": "binary_with_partial",  
  "thresholds": {  
    "1.0": "All requirements met",  
    "0.75": "Most requirements met, minor gaps",  
    "0.5": "Some requirements met",  
    "0.0": "Requirements not met"  
  }  
}
```

2. Weighted Factors

```
{  
  "method": "weighted_factors",  
  "factors": {  
    "factor_1": { "weight": 0.30, "thresholds": { ... } },  
    "factor_2": { "weight": 0.25, "thresholds": { ... } },  
    ...  
  }  
}
```

Final score = $\text{sum}(\text{factor_score} \times \text{weight})$

3. Checklist Percentage

```
{
  "method": "checklist_percentage",
  "checklist_items": {
    "item_1": { "weight": 0.20, "description": "..."},
    "item_2": { "weight": 0.25, "description": "..."},
    ...
  },
  "calculation": "sum(item_present × weight)"
}
```

Module-Level Scoring

Each module aggregates criteria using **weighted average**:

$\text{Module_Score} = \text{sum}(\text{Criterion_Score} \times \text{Criterion_Weight})$

Note: N/A criteria are excluded and weights renormalized.

Example:

Module 2 Fairness:

- F2.1: $0.85 \times 0.35 = 0.2975$
- F2.2: $0.90 \times 0.25 = 0.2250$
- F2.3: $0.75 \times 0.25 = 0.1875$
- F2.4: N/A (not applicable, geographic exemption)

Weights renormalized: $0.35 + 0.25 + 0.25 = 0.85 \rightarrow 100\%$

New weights: $0.35/0.85 = 0.412$, $0.25/0.85 = 0.294$, $0.25/0.85 = 0.294$

$$\begin{aligned} \text{Final Score} &= (0.85 \times 0.412) + (0.90 \times 0.294) + (0.75 \times 0.294) \\ &= 0.350 + 0.265 + 0.221 \\ &= 0.836 = 83.6\% \text{ (PASS, above 0.75 threshold)} \end{aligned}$$

Overall Audit Score

Without Council of Experts:

$\text{Overall_Score} = \text{weighted_average}(\text{Module_Scores})$

With Council of Experts (v3.0+):

Arbitrator produces confidence-weighted composite score considering:

- Module scores
 - Peer review consensus
 - Divergence flags
 - Trigger activations
-

14. SOX 404 Classification

Definitions (per COSO Framework)

Material Weakness: > A deficiency, or combination of deficiencies, in internal control over financial reporting, such that there is a reasonable possibility that a material misstatement of the company's annual or interim financial statements will not be prevented or detected on a timely basis.

Significant Deficiency: > A deficiency, or combination of deficiencies, in internal control over financial reporting that is less severe than a material weakness, yet important enough to merit attention by those responsible for oversight of the company's financial reporting.

Control Deficiency: > A deficiency in the design or operation of a control that does not permit personnel, in the normal course of performing their functions, to prevent or detect misstatements on a timely basis.

Classification Rules

By Score Range:

Score	Classification	Disclosure Required
0.0-0.5	Material Weakness	Yes - 10-K Item 9A
0.51-0.75	Significant Deficiency	Yes - Management letter
0.76-1.0	Pass (or Control Deficiency)	No public disclosure

By Materiality Impact:

If materiality calculation shows: - **Materiality Multiple** > 1.0 → Material Weakness (regardless of score) - **0.5 < Multiple ≤ 1.0** → Significant Deficiency - **Multiple ≤ 0.5** → Control Deficiency

Final Classification: Use more severe of score-based or materiality-based classification.

Audit Opinion Impact

Material Weakness: - Likely qualified opinion - Possible adverse opinion on ICFR - CEO/CFO certifications affected - 10-K disclosure required (Item 9A)

Significant Deficiency: - Unqualified opinion may still be possible - Management letter disclosure - Remediation plan required

15. Implementation Guide

Phase 1: Schema Setup (Week 1)

Tasks: 1. Load all 5 module schemas (JSON files) 2. Validate schemas against JSON Schema Draft-07 3. Create evidence collection templates 4. Configure materiality thresholds (Overall Materiality, Performance Materiality)

Deliverables: - 5 validated JSON schema files - Evidence template library (Excel/PDF templates) - Materiality configuration file

Phase 2: Evidence Collection (Weeks 2-3)

Tasks: 1. Deploy evidence templates to AI system owners 2. Collect governance documents (Module 1) 3. Collect fairness testing results (Module 2) 4. Collect security configurations and privacy documentation (Module 3) 5. Collect explainability artifacts and audit logs (Module 4) 6. Collect validation reports and monitoring logs (Module 5)

Key Privacy Evidence (NEW in v3.1): - ROPA (Record of Processing Activities) - DPIA (Data Protection Impact Assessments) - Breach notification procedures - Data retention policies - Opt-out mechanisms - Correction request logs

Phase 3: Evaluation Execution (Week 4)

Tasks: 1. Run all 5 modules in parallel (Stage 1) 2. Evaluate interdependency trigger conditions 3. Execute triggered modules with modified parameters 4. Run Council of Experts peer review (Stage 2) if enabled 5. Arbitrator synthesis (Stage 3) if Council enabled

Orchestration Flow:

1. All modules execute → Initial findings
2. Orchestrator checks triggers → Conditions evaluated
3. Triggered modules re-execute → Additional findings
4. (Optional) Peer review → Cross-domain scores
5. (Optional) Arbitrator → Final composite score
6. Synthesis report → SOX classifications, materiality impacts

Phase 4: Reporting (Week 5)

Report Components: 1. Executive Summary 2. Overall SOX 404 classification 3. Module-by-module findings 4. Materiality pyramid visualization 5. Evidence traceability matrix 6. Regulatory compliance gap analysis 7. Interdependency trigger activation log 8. Council Scorecard (if applicable) 9. Recommendations with priority rankings

Phase 5: Remediation & Follow-Up (Ongoing)

Process: 1. Management response to findings 2. Remediation plan development 3. Implementation tracking 4. Re-testing of remediated controls 5. Quarterly monitoring for Material Weaknesses

16. Validation & Testing

Schema Validation

Tool: Python jsonschema library

```
import jsonschema
import json
```

```

# Load schema
with open('module1_governance_schema_v3_1.json') as f:
    schema = json.load(f)

# Validate against JSON Schema Draft-07
jsonschema.Draft7Validator.check_schema(schema)
print("Schema valid!")

# Validate sample data
with open('sample_data_module1.json') as f:
    data = json.load(f)

jsonschema.validate(instance=data, schema=schema)
print("Sample data valid!")

```

Required Validation Checks

1. **Schema Structure:**
 - Valid JSON Schema Draft-07
 - All required top-level fields present
 - Consistent criterion ID naming (G1.1, F2.1, etc.)
2. **Criterion Completeness:**
 - Each criterion has: ID, name, description, check_method, pass_criteria, evidence_required, scoring, severity_mapping
 - Evidence templates include all required fields
 - Scoring thresholds logically ordered
3. **Regulatory Mapping:**
 - All claimed regulatory alignments cited correctly
 - GDPR articles cited accurately (Article numbers and content match)
 - CCPA sections cited accurately
4. **Scoring Consistency:**
 - Weights sum to 1.0 (allowing for rounding to 0.01)
 - Thresholds monotonically ordered
 - Severity mappings consistent across modules
5. **Geographic Exemptions:**
 - All GDPR/CCPA criteria have exemption handling
 - Exemption documentation requirements specified

Testing with Sample Data

Test Cases Required:

1. **All Criteria Pass** → Overall score >0.75, PASS
2. **Material Weakness** → Materiality exceeded, MW classification
3. **Trigger Activation** → T1.1 triggers Module 2 escalation
4. **Geographic Exemption** → GDPR criteria scored N/A correctly

5. Council Divergence → Score spread >20 pts triggers HITL

Acceptance Criteria

Schema implementation is complete when:

- ☐ All 5 schemas validate against Draft-07
- ☐ 5 test cases pass for each module (25 total)
- ☐ Evidence templates generated and validated
- ☐ Materiality calculation produces expected classifications
- ☐ Interdependency triggers execute correctly
- ☐ Council scorecard generates for divergent scenarios
- ☐ Regulatory mapping verified against source documents
- ☐ Geographic exemptions handle correctly
- ☐ Sponsor (Dr. Fortino) acceptance received

Appendix A: Criterion ID Reference

Quick lookup of all 28 criteria:

Module	Criterion IDs	Count
M1: Governance	G1.1, G1.2, G1.3, G1.4, G1.5, G1.6, G1.7	7
M2: Fairness	F2.1, F2.2, F2.3, F2.4	4
M3: Security & Privacy	S3.1, S3.2, S3.3, S3.4, S3.5, S3.6	6
M4: Explainability	E4.1, E4.2, E4.3, E4.4, E4.5	5
M5: Accuracy	A5.1, A5.2, A5.3, A5.4, A5.5	5
TOTAL		28

Appendix B: GDPR/CCPA Quick Reference

When GDPR Applies

 **Applies if:** - Processing personal data of individuals in the EU - Regardless of where organization is based - Even if just one EU resident's data processed

 **Does not apply if:** - No personal data of EU residents processed - Processing purely domestic within non-EU country - Data already anonymized (not personal data)

Exemption Documentation: Legal opinion + geographic scope analysis

When CCPA Applies

✅ **Applies if:** - Processing personal information of California residents - Organization does business in California OR - Annual gross revenues >\$25M OR - Buys/sells personal information of ≥100,000 California consumers

❌ **Does not apply if:** - No California resident data - Small business below thresholds - B2B data only (limited exemption)

Exemption Documentation: Legal assessment + business operations analysis

Key Differences

Aspect	GDPR	CCPA
Geographic Scope	EU residents worldwide	California residents only
Legal Basis Required	Yes (6 bases: consent, contract, legal obligation, vital interests, public task, legitimate interests)	No general legal basis requirement
Special Category Data	Requires explicit consent or specific exemption	Protected classes covered by anti-discrimination rules
Right to Erasure	Broad right (Article 17) with exemptions	Right to delete (§1798.105) with exemptions
Breach Notification	72 hours to authority	Prompt to AG if >500 residents
Penalties	€20M or 4% global turnover	\$7,500 per intentional violation
Private Right of Action	No (enforcement by authorities)	Yes for data breaches (§1798.150)

Appendix C: Common Questions

Q1: Can a criterion be scored N/A?

A: Yes, privacy criteria can be scored N/A if: - Organization does not process EU resident data (GDPR) - Organization does not process California resident data (CCPA) - AI system does not make decisions with legal/significant effects (GDPR Article 22, CCPA automated decision-making)

Requirements: - Must provide exemption documentation (legal opinion or geographic scope analysis) - Weights automatically renormalized across applicable criteria - N/A scoring does NOT lower the bar for passing (pass threshold remains constant)

Q2: What if a module has all privacy criteria scored N/A?

A: Example: Module 2 for a purely domestic US (non-California) organization

- F2.1: Fairness metrics still evaluated (weight 35%)

- F2.2: Bias monitoring still evaluated (weight 25%)
- F2.3: Mitigation still evaluated (weight 25%)
- F2.4: Scored N/A (no EU/CA data, no automated decisions with legal effects)

Result: - Original weights: 35% + 25% + 25% + 15% = 100% - Applicable weights: 35% + 25% + 25% = 85% - Renormalized: 35/85 = 41.2%, 25/85 = 29.4%, 25/85 = 29.4% - Pass threshold: Still 0.75 (not lowered)

Q3: How is materiality calculated for privacy violations?

A: See Module 3 (S3.5) breach impact formula:

Breach_Impact = Records × Per_Record_Cost
 + GDPR_Fine
 + CCPA_Fine
 + Notification_Cost

If Breach_Impact > Overall_Materiality → Material Weakness

Q4: What triggers the Council of Experts?

A: Council is optional enhancement (v3.0+). When enabled: - Stage 1: Always runs (independent module scoring) - Stage 2: Always runs (peer review) - Stage 3: Runs when divergence ≥ 10 pts or complexity flags present

Q5: Can findings from interdependency triggers override original module scores?

A: Triggers do NOT override scores but: - Add additional findings to the triggered module - May escalate severity classifications - Provide additional context for Arbitrator (Council) - Documented separately in trigger activation log

Example: - Module 5 scores A5.1 = 0.70 → Significant Deficiency - Materiality calculation: \$44.7M (8.94× materiality) - Trigger T5.2 activates: Investigates governance - Final classification: Material Weakness (due to materiality) - Governance investigation adds separate finding to Module 1

Document Revision History

Version	Date	Author	Changes
1.0	2026-01-20	Wenguang Li	Initial documentation for 5 modules, 17 criteria
2.0	2026-02-12	Wenguang Li	Added interdependency triggers, materiality framework, evidence templates
3.0	2026-03-01	Wenguang Li	Added Council of Experts, divergence handling
3.1	2026-03-07	Wenguang Li	GDPR/CCPA integration , 28 criteria, privacy evidence templates, Module 3 expansion
